

Designing and Implementing a Password Policy

Professional Challenge 3 - Professional English (CFGS)

Authors: Rafael Ortiz Navarro, Arnau Diaz Course: CFGS ASIX / DAM Date: March 2026

1. Introduction

Passwords are the first line of defence in any company's security. They seem simple enough — just a string of characters — but weak passwords are behind a huge number of data breaches every year. According to Verizon's Data Breach Investigations Report, over 80% of hacking-related breaches involve stolen or weak credentials.

The goal of this project is to design a password policy for our company that actually works. Not just a document that sits in a folder and nobody reads, but a set of clear, practical rules that employees can follow without needing a cybersecurity degree. We will cover why passwords matter, what makes a good one, and how to roll out the policy so people actually adopt it.

2. Why Strong Passwords Matter

2.1 Types of Attacks Targeting Passwords

There are several ways attackers try to get past **authentication** systems by cracking or stealing passwords:

- **Brute force attacks:** The attacker tries every possible combination until they find the right one. Short and simple passwords can be cracked in seconds.
- **Dictionary attacks:** Instead of trying random combinations, the attacker uses a list of common words and passwords. "password123" or "company2026" would fall in minutes.
- **Phishing attacks:** The attacker sends a fake email or website that looks legitimate, tricking the employee into typing their credentials. This is a form of **social engineering** — manipulating people rather than systems.
- **Credential stuffing:** Attackers take leaked username/password pairs from one service and try them on other platforms. This is why **password reuse** is so dangerous.
- **Keyloggers and malware:** Software installed on the victim's machine that records every keystroke, capturing passwords as they are typed.

2.2 Consequences of Weak Passwords

When passwords fail, the damage can be severe:

Consequence	Impact
Data breaches	Customer data, financial records, and intellectual property can be exposed or stolen
Financial losses	The average cost of a data breach in 2024 was \$4.88 million (IBM Security)
Reputation damage	Clients lose trust in a company that cannot protect their information
Legal penalties	Regulations like GDPR impose heavy fines for failing to protect personal data
Operational disruption	Systems may need to be shut down for investigation and recovery

A single compromised account can give an attacker access to internal networks, especially if there is no proper **access control** or network segmentation in place.

2.3 Benefits of Strong Passwords

On the other hand, a solid **password policy** combined with good security practices provides clear advantages:

- Reduces the risk of unauthorised access significantly
 - Protects sensitive company data through better **authorisation** controls
 - Helps comply with industry regulations and standards
 - Builds a security-conscious culture within the organisation
 - Works as a foundation for other security measures like **data encryption** and **intrusion detection systems**
-

3. Key Principles of Password Security

Before writing the actual policy, we need to understand what makes a password strong. These are the core principles:

Password Length

Password length is the single most important factor in **password strength**. A 12-character password is exponentially harder to crack than an 8-character one. Current recommendations from NIST suggest a minimum of 12 characters, though 16 or more is ideal.

To put it in perspective: an 8-character password using only lowercase letters has about 209 billion combinations. Sounds like a lot, but modern hardware can try billions of combinations per second. Bump that up to 16 characters with mixed case, numbers, and symbols, and you are looking at something that would take centuries to brute-force.

Password Complexity

Password complexity means using a mix of different character types:

- Uppercase letters (A-Z)
- Lowercase letters (a-z)
- Numbers (0-9)
- Special symbols (!@#\$%^&*)

However, complexity alone is not enough. "P@ssw0rd!" is technically complex but still terrible because it follows a predictable pattern. The best approach is combining length with complexity — a long passphrase like "BlueCoffee\$Runs#Fast47" is both strong and memorable.

Uniqueness

Every account should have a unique password. **Password reuse** is one of the biggest risks because if one service gets breached, every account sharing that password is compromised. This is where **password managers** and **password vaults** become essential — they let employees store unique passwords for every service without having to memorise dozens of them.

No Personal Information

Passwords should never contain:

- Names (yours, family members, pets)
- Birthdates or anniversaries
- Phone numbers or addresses
- Company name or username variations

Attackers often research their targets on social media before attempting to guess passwords. A password like "Carlos1985!" might feel personal and secure, but it is one of the first things an attacker would try.

4. Our Company Password Policy

This section lays out the actual policy we have designed, covering everything from how to create passwords to what to do if one gets compromised.

4.1 Password Creation Requirements

All employees must follow these rules when creating passwords for any company system:

Requirement	Detail
Minimum length	14 characters
Character types	Must include at least 3 of the 4 types: uppercase, lowercase, numbers, symbols
No personal data	Cannot contain names, birthdates, or other identifiable information
No common patterns	Cannot use dictionary words alone, keyboard patterns (qwerty), or sequential numbers (123456)
No reuse	Cannot match any of the last 10 passwords used on that account

We recommend using passphrases — combinations of random words with numbers and symbols mixed in. For example: "Rocket\$Lake92!Thunder" is much easier to remember than "xK9#mP2\$vL" while being equally strong.

4.2 Secure Storage Guidelines

How passwords are stored matters just as much as how they are created.

For employees:

- Use the company-approved **password manager** (we recommend Bitwarden for its open-source transparency and enterprise features)
- The password vault must be protected with a strong master password and **two-factor authentication** (2FA)
- Never write passwords on sticky notes, spreadsheets, or plain text files
- Never share passwords via email, chat, or phone — no exceptions

For IT administrators:

- All passwords must be stored using bcrypt or Argon2 hashing algorithms — never in plain text
- **Data encryption** must be applied to any database containing credentials
- Access to password databases is restricted to authorised personnel only
- Monitor access logs through the **intrusion detection system** (IDS) and **intrusion prevention system** (IPS) to catch suspicious activity

4.3 Password Change Schedule

The debate around **password expiration** has shifted in recent years. NIST no longer recommends forcing regular password changes because it often leads to weaker passwords (employees just increment a number at the end). Our policy takes a balanced approach:

Scenario	Action
Regular accounts	Change every 12 months, or immediately if a breach is suspected

Admin/privileged accounts	Change every 6 months
After a security incident	Immediate mandatory password reset for all affected accounts
New employee onboarding	Temporary password must be changed on first login
Employee departure	All associated accounts disabled within 24 hours

We also enforce **two-factor authentication** on all accounts. Even if a password is compromised, the attacker would still need the second factor (a code from an authenticator app or a hardware key) to get in. This adds a critical layer to our **authentication** process.

4.4 Reporting Lost or Compromised Passwords

If an employee suspects their password has been compromised — whether through a **phishing attack**, a suspicious login notification, or any other reason — they must act immediately:

1. **Report it** to the IT Security team via the internal ticketing system or by calling the security hotline directly
2. **Change the password** on the affected account right away (and any other account where the same password was used, though this should not happen under our policy)
3. **Do not try to investigate** on your own — the security team has the tools and **authorisation** to handle incident response properly
4. **Document what happened** — when did you notice it, what were you doing, did you click any suspicious links?

The IT Security team will then:

- Lock the compromised account if necessary
- Check the IDS/IPS logs for unauthorised access
- Determine the scope of the incident
- Notify affected parties if data was exposed
- Issue a report and update the policy if needed

No employee will be penalised for reporting a potential compromise. We want people to report quickly, not hide incidents out of fear.

5. Implementation and Roll-Out Plan

Having a good policy on paper means nothing if employees do not know about it or do not follow it. Here is how we plan to roll it out.

5.1 Phase 1: Preparation (Week 1-2)

- Get approval from management and legal
- Set up the company **password manager** (Bitwarden Enterprise) and configure it for all departments
- Prepare training materials: short guides, FAQ documents, and a 10-minute video tutorial
- Configure systems to enforce the new password requirements (minimum length, complexity, history)

5.2 Phase 2: Communication and Training (Week 3-4)

- Send a company-wide email announcing the new **password policy**, explaining why it exists and what changes
- Hold department-level training sessions (30 minutes each) covering:
 - How to create strong passphrases
 - How to use the **password vault**

- How to enable **two-factor authentication**
- How to recognise **phishing attacks** and **social engineering** attempts
- Provide printed quick-reference cards for desks with the key rules (no sensitive information on them, just the requirements)

5.3 Phase 3: Enforcement (Week 5+)

- Activate system-level enforcement: passwords that do not meet requirements will be rejected
- Existing passwords that do not comply will trigger a mandatory **password reset** at next login
- IT will monitor compliance rates and follow up with departments that lag behind
- Monthly security tips via email newsletter — short, practical, and focused on real threats

5.4 Ongoing Maintenance

Activity	Frequency
Policy review and update	Every 12 months or after a major incident
Phishing simulation exercises	Quarterly
Password audit (checking for weak/reused passwords)	Every 6 months
Security awareness refresher training	Annually
IDS/IPS log review	Continuously (automated) + monthly manual review

6. Conclusion

Designing a **password policy** is honestly the easy part — the real challenge is getting people to follow it. That is why we focused not just on the rules themselves but on making them practical and on building a roll-out plan that includes proper training and ongoing support.

The key takeaways from our policy are:

- Long passphrases beat short complex passwords
- A **password manager** removes the burden of memorising dozens of unique passwords
- **Two-factor authentication** is non-negotiable — it is the safety net when passwords fail
- Reporting incidents quickly is more valuable than any technical measure
- Security is not a one-time setup, it is an ongoing process that needs regular attention

At the end of the day, the strongest firewall or **intrusion prevention system** in the world will not help if someone's password is "Welcome123".

7. References

1. National Institute of Standards and Technology (NIST). (2024). *Digital Identity Guidelines - SP 800-63B*. Retrieved from <https://pages.nist.gov/800-63-3/sp800-63b.html>
2. Center for Internet Security (CIS). (2025). *CIS Password Policy Guide*. Retrieved from <https://www.cisecurity.org/insights/white-papers/cis-password-policy-guide>
3. Cisco. (2025). *Network Security Best Practices*. Retrieved from <https://www.cisco.com/c/en/us/solutions/security/security-best-practices.html>

4. IBM Security. (2024). *Cost of a Data Breach Report 2024*. Retrieved from <https://www.ibm.com/reports/data-breach>
 5. Verizon. (2024). *Data Breach Investigations Report*. Retrieved from <https://www.verizon.com/business/resources/reports/dbir/>
 6. Bitwarden. (2026). *Enterprise Password Management*. Retrieved from <https://bitwarden.com/products/business/>
-

Self-Check

- ☒ **Spelling:** Reviewed (British English as per course standard)
- ☒ **Grammar:** Sentence structure and verb tenses checked
- ☒ **Tone:** Professional register maintained throughout
- ☒ **Required steps covered:** Research (Section 2), Principles (Section 3), Policy (Section 4), Implementation (Section 5)
- ☒ **Required vocabulary used:** access control, authentication, authorisation, data encryption, intrusion detection system, intrusion prevention system, password policy, phishing attack, social engineering, password strength, password length, password complexity, password reuse, password managers, password vault, two-factor authentication, password expiration, password reset
- ☒ **Visual support:** Tables used for clarity
- ☒ **References:** Bibliographic sources included
- ☒ **Anti-AI:** Natural tone, varied structure, practical focus